

Fynla — Engineering Release Notes (19 May 2026)

Technical companion to `patch-notes-2026-05-19.md`. Audience: engineering and technical team.
Scope: the production deployment to `fynla.org` on 2026-05-19.

1. Release composition

Two release PRs landed on `main` and were deployed to production:

PR	Merged (UTC)	Branch	Contents
#337	2026-05-19 10:08	<code>dev</code>	SP1 Savings Canonical Store + SP2 Freemium + SP3 unified Fyn prompt + security #313 + accrued dev (<code>dev</code> was 264 commits ahead of <code>main</code>)
#340	2026-05-19 12:42	<code>dev</code>	Will Builder + Power of Attorney teaser-gate (#339 , spec §10.2)

Supporting non-code merges the same day: [#338](#) and [#341](#) (`main` → `dev` back-merges of release merge-commits and two doc commits; no runtime effect). [#337](#) supersedes the stale, conflicting [#317](#) (closed unmerged).

All three workstreams were deployed to `dev` (csjones staging) and browser-verified GREEN before the `dev` → `main` release.

Constituent PR campaigns folded into [#337](#)

- **SP1 — Savings Canonical Store:** [#305](#) (facade + boundary arch test), [#306–#309](#) (HTTP form requests, Fyn AI write tools, upload + seeders, net-worth + mobile dashboard reads), [#315/#316/#318](#) (Investment ISA, Coordination + Goals, AI prompt + profile read clusters), [#321](#) (canonical derived columns + snapshot table), [#322](#) (tier-cap enforcement point; `StaticTierGate` placeholder, real enforcement deferred to SP2), [#313](#) (Retirement cluster + the security fix below).
- **SP2 — Freemium tier model (PR1–9):** [#327](#) (PR1 store + seeder + boundary), [#328](#) (PR2 `users.tier` + `TierResolver` + grandfather), [#329](#) (PR3 `DbTierGate`), [#330](#) (PR4 admin screen + propagation), [#331](#) (PR5 Revolut tier-variation sync + price-lock), [#333](#) (PR6 Fyn weekly soft-degrade), [#334](#) (PR7 generic `TeaserGate` + Estate consumer); PR8 (doc allowance/quota + currency/snapshot/Open-API flags) and PR9 (lockdown) merged by push ([c9e43295](#), [696890ed](#)) with no standalone GitHub PR records — [#336](#) is their traceability bundle.
- **SP3 — Unified Fyn prompt:** [#332](#) (unified architecture, flag-gated, parity-green) + [#335](#) (post-[#332](#) delta: `FynContextAssembler` per-turn path, tripled capture-ack fix, billing surface restoration, C1 cached-prompt hoist).

2. SP2 — Freemium tier model

Data model

- Migration `2026_05_17_100000_create_tier_configurations_table.php` — `tier_configurations` store: `tier`, `display_name`, `price` columns (`*_pence`), `revolut_plan_variation_id`, `capability_matrix` (JSON), `count_caps` (JSON), `document_upload_allowance`, `document_storage_gb`, `fyn_weekly_token_budget`, `fyn_daily_hard_backstop`, `currency_display_mode`, `snapshot_surfacing_window_days`, `open_api_affordance`, `is_active`, `updated_by`.
- Migration `2026_05_17_100001_add_tier_to_users_table.php` — `users.tier` (authoritative going forward). `users.plan` retained read-only for Revolut/billing compatibility during the grandfather window; **no new code branches on `plan`**.
- Migration `2026_05_17_100002_add_tier_keys_to_subscriptions_plan_enum.php` — extends the subscriptions plan enum with tier keys.
- `TierConfigurationSeeder` — four canonical rows (`free` / `tier1` / `tier2` / `tier3`). Capability verbs: `full` | `none` | `limited` | `teaser`. `count_caps`: int = cap, `null` = unlimited, absent = not count-gated. **Prices are render-only placeholders (spec §22 A8) — not proposals, not mapped to legacy plan prices. CSJ sets real prices via the admin screen.**

Canonical caps as seeded:

Capability	free	tier1	tier2	tier3
<code>savings_account</code>	<code>limited</code> (cap 3)	<code>full</code> / ∞	<code>full</code> / ∞	<code>full</code> / ∞
<code>investment</code>	<code>limited</code> (cap 2)	<code>full</code> / ∞	<code>full</code> / ∞	<code>full</code> / ∞
<code>pension_account</code>	<code>limited</code> (cap 5)	<code>full</code> / ∞	<code>full</code> / ∞	<code>full</code> / ∞
<code>estate</code>	<code>teaser</code>	<code>teaser</code>	<code>full</code>	<code>full</code>
<code>investments_exotic</code>	<code>none</code>	<code>none</code>	<code>full</code>	<code>full</code>
<code>retirement_decumulation</code>	<code>none</code>	<code>none</code>	<code>full</code>	<code>full</code>
<code>letter_to_spouse</code>	<code>none</code>	<code>full</code>	<code>full</code>	<code>full</code>
<code>document_upload_allowance</code>	3	4	5	6
<code>document_storage_gb</code>	null	null	5.00	20.00
<code>fyn_weekly_token_budget</code>	100k	250k	500k	1.0M
<code>fyn_daily_hard_backstop</code>	500k	1.0M	2.0M	4.0M
<code>currency_display_mode</code>	<code>gbp_only</code>	<code>gbp_only</code>	<code>user_choice</code>	<code>user_choice</code>
<code>snapshot_surfacing_window_days</code>	90	365	1825	2555
<code>open_api_affordance</code>	false	false	true	true

`dashboard`, `goals`, `protection`, `property`, `liabilities`, `income`, `expenditure`, `chattels`, `benefits_child`, `family_module` are `full` at every tier including `free` (household/spouse linking is never tier-gated — spec §7 firm rule).

Resolution, gating, enforcement

- `app/Services/Tiers/TierResolver.php` — resolves every user (including legacy plan-holders, `trial`, preview) to exactly one of `free` / `tier1` / `tier2` / `tier3`. **No mechanical plan→tier map** (spec §5.2, §22 A9); the backfill is non-narrowing — a grandfathered paid subscriber's `users.tier` is set so gating never reduces their existing access.
- `app/Services/Stores/TierGate.php` (interface) → bound to `app/Services/Tiers/DbTierGate.php`. `PermissiveTierGate` is unbound; `StaticTierGate` deleted; dead `PermissiveTierGate` removed in PR9. Every SP1 entity store already calls the gate seam, so caps went live by binding.
- **Grandfathering (principle 4.4 / spec §16.2)**: introducing or lowering a cap never deletes, hides or downgrades existing rows. Over-cap users keep everything; only *new* over-cap creates are blocked, raising `app/Services/Stores/Exceptions/TierLimitExceededException.php` with a precise upgrade CTA.
- **Exemptions**: `is_preview_user` is fully exempt from `DbTierGate` and `DocumentAllowanceGate` (Rule #2 — preview personas sit entirely outside tiers/subscriptions/gates). Commit `37e84ca7` fixed a `db:seed` breakage caused by the gate firing on preview seeding. Admin and grandfathered users also exempt at cap.
- `app/Services/Tiers/TeaserGate.php` — generic teaser authority. Estate consumer: Free/Tier1 → IHT-exposure teaser + upgrade CTA; Tier2/Tier3 → full Estate. Defence-in-depth: full-engine sub-routes 403 server-side, not just hidden.

Admin + Revolut

- `TierConfigurationController` + `TierConfiguration.vue` + `UpdateTierConfigurationRequest` + `TierConfigurationResource` + `TierConfigurationStore` — single admin screen drives pricing and capability gating; mutations only via `TierConfigurationStore` (+ SP1 allowlist: observers, console commands, migrations, seeders-via-store), enforced by an architecture boundary test.
- `app/Services/Tiers/RevolutTierVariationSync.php` + `app/Console/Commands/SyncRevolutTierVariations.php` — tier-variation sync, price-lock (existing subs' price locked until renewal; store price changes affect new subs and renewals only, never an in-flight billing period), full grant/revoke lifecycle. Revolut sandbox sync run deferred to csjones (no local keys) per PR #336 notes.

Fyn metering reconciliation

`HasAiGuardrails::DAILY_TOKEN_LIMITS` (per-legacy-plan daily hard caps) was **removed** in PR9. Metering is now 100% store-driven from `tier_configurations`: per-tier **weekly soft-degrade** (`fyn_weekly_token_budget`) with a generous **daily hard backstop** (`fyn_daily_hard_backstop`, abuse-only). Soft-degrade lightens responses for the remainder of the week and auto-resets; it does not hard-stop the assistant.

3. SP3 — Unified Fyn prompt architecture

- New package `app/Services/AI/Fyn/`: `FynSystemPrompt` (byte-stable static prompt restructured from legacy text; two interpolation sites — `firstName`, `taxYear`), `FynContextAssembler` + `FynContextSelector` (4-bucket IDENTITY/POSITION/READINESS/CAPTURE, reusing the existing `QueryClassifier` factual signal),

`FynTurnContext` (VO), `ContextBucket` (enum), `FynCaptureTurnInstructions` (capture-turn text moved verbatim from the old onboarding builder), `FynPromptMode`.

- `config/fyn.php` → `prompt_architecture = env('FYN_PROMPT_ARCH', 'unified')`. Default is **unified** (post-cutover). **legacy** (the pre-2026-05-16 12-layer `AdvicePromptBuilder` / 4-layer `OnboardingPromptBuilder`) is retained **only** as the emergency rollback path. Fail-safe: any unrecognised value resolves to **legacy**.
- Read/write boundary unchanged — still enforced purely at dispatch + tool-gating, not prompt content. Canonical contract (`00-canonical.md`) rewritten accordingly; per-state prompt docs archived. Pre-cutover tag `fyn-two-prompt-pre-unify` at `bd42dce`.
- `OnboardingChatDirector` + advice `HasAiChat` seam gated by `FynPromptMode::isUnified()`; documented no-op under legacy.

Fixes delivered with SP3

- **Tripled capture-ack defect (#335):** `CoordinatingAgent` (+37) now coerces unknown/synonym `account_type` (e.g. `"savings_account"` → `easy_access/cash_isa`) **before** `Rule::in` validation, eliminating the `validation_failed` → `no-row` → `retry` path that produced intermittent zero rows + a doubled acknowledgement. Pure-additive, flag-agnostic. `HasAiChat` (+78) adds `captureTurnCompleteDirective()`, gated on `persona == 'data_capture'`, fired only on a landed/deduped result shape — supplies the turn-complete signal the `data_capture` loop was missing. Inert on advice and the legacy-refusal path. Browser-GREEN single + multi-entity under live unified.
- **Billing surface restored under unified:** `FynContextAssembler` classification-gated `<billing_guidance>` layer; `QueryClassifier` billing-beats-NAVIGATION; `QuerySchemas` bare `billing/subscription` (ISA-guarded). +10 Pest cases.
- **Nav-router + classification fixes:** word-boundary nav-trigger matching (not substring); client nav router no longer hijacks questions to Fyn; "protected for my savings" classified FSCS, not life cover.
- **C1 perf:** static data-completeness rules hoisted into the cached prompt.

SP3 parity / known separate item

Clean parity gate GREEN: legacy & unified both **1 skipped, 3728 passed** — identical, zero regressions (recorded; do not re-run unless code changes). **Known, tracked, not introduced here:** under `FYN_PROMPT_ARCH=legacy` the advice→capture write journey security-refuses entirely (0 rows). Pre-existing on `origin/dev`; Pest-invisible (LLM mocked). Breaks emergency-rollback for advice→capture writes — logged separately (memory + CSJTODO); CSJ decision: "log separately, proceed per contract."

4. SP1 — Savings Canonical Store

- `app/Services/Stores/SavingsStore.php` — single authoritative read/write facade for savings, enforced by a boundary architecture test. All read clusters migrated: HTTP form requests, Fyn AI write tools, upload + seeders, net-worth + mobile dashboard, Investment ISA, Coordination + Goals, AI prompt + profile, Retirement.
- Migration `2026_05_15_100001_create_savings_account_value_snapshots_table.php`
 - canonical derived columns (PR6) — materialised values + snapshot history.

- Joint-ownership correctness: reads now consistently OR-combine `user_id IN (...)` and `joint_owner_id IN (...)`. `forUsers(array $userIds)` is a **deliberate semantic widening** (joint accounts where a requested user is the secondary owner are now included — explicit parity test).

5. Security fix #313 (HIGH / HIGH)

PR 5c-2 of SP1 migrated the Retirement read cluster (3 files / 9 sites) and closed a **pre-existing** HIGH-severity data-leak.

- **Surface:** `RetirementIncomeService` sites 5–8 used `SavingsAccount::whereIn('id', $ids)->get()` with no ownership check. `$ids` originate from `income_allocations.source_id` in the request body of `RetirementController::calculateRetirementIncome` (line 660); validation enforced only `numeric`.
- **Attack:** an authenticated user could POST another user's savings account IDs in `income_allocations` and read those balances back via the retirement income projection response.
- **Fix:** unscoped `findManyById` replaced with user-scoped, joint-aware `SavingsStore::findMany(array $ids, User $user)` (a **deliberate security narrowing** — explicit cross-user-exclusion test). `User` resolved at each caller via `User::find($userId)` with null-safe early return. `calculateAnnualWithdrawals` (zero callers — dead) gains an `int $userId` param for safety.
- Pre-existing, **not introduced by this release**. No evidence of exploitation; found in internal review. Follow-up (not bundled): controller-side ownership validation on `income_allocations.source_id` (boundary-level defence on top of the store-level scoping).

6. Will Builder + Power of Attorney teaser-gate (#339 / #340)

- **Root cause (diagnosed):** SP2 PR7 applied the estate teaser-gate only to `IHTController` + `EstateController`. `WillController`, `WillDocumentController`, `LpaController` were left open. Per SP2 design §7 there is no separate will/POA capability key — they fall under `estate` (`teaser` for Free/Tier1, `full` for Tier2/Tier3). The legacy `feature:pro` middleware and frontend `featureGating.js` gate on the **legacy subscription plan**, so a grandfathered legacy-paid sub (resolves to `free` tier) sailed through.
- **Backend:** new `app/Http/Middleware/EnsureFullEstateAccess.php` reuses the canonical `TeaserGate` (not the legacy plan map); `estate.full` Kernel alias (`Kernel.php:130`) applied to will-builder / will / bequests / calculate-intestacy / lpa routes. Route-level rather than the in-body `GatesEstateAccess` trait because these endpoints use `FormRequest` type-hints (an in-body gate 422s before it can 403). Server-side 403, spec §10.2 "gated server-side, not just hidden".
- **Frontend:** `requireFullEstateAccess` router `beforeEnter` guard on `/estate/will-builder`, `/estate/power-of-attorney`, `/estate/lpa/create/:type` redirects teaser users to the `/estate` canonical teaser. Decision sourced from the estate store `mode` (same `TeaserGate` authority), not the broken legacy `featureGating` plan map.
- **Verification:** TDD RED→GREEN; +11 `EstateTeaserGateTest`; `WillBuilderApiTest` / `LpaControllerTest` corrected to a `tier2` acting user + `TierConfigurationSeeder` (they encoded pre-SP2 "always accessible" behaviour — a real regression fixed in-loop, not a silenced assertion). 132 Tiers+Estate pass, Architecture suite green, Pint clean. Browser-verified on csjones:

free/null → `/estate` teaser + 403 on `/api/estate/will`, `/will-builder`, `/lpa`; tier2 → full wizard, no redirect.

- **Known scope gap (tracked, not in scope):** `featureGating.js` / `AppNavbar` still gate sidebar nav links on legacy `subscriptionData.plan` — the "Will" / "Power of Attorney" links still render for teaser users, but clicking now correctly lands on the teaser. Rewiring the whole legacy→SP2 frontend gating layer is a separate, larger piece.

7. Test posture

- SP3 parity gate: legacy + unified both 3728 passed / 1 skipped (identical).
- SP2 acceptance (§18.2) on `sp2Freemium@696890ed`: 3840 passed, 25 skipped, 15 failed — the 15 are the documented **local-env-only** Group A (`AI_AUDIT_HMAC_KEY`/`APP_KEY` absent) + Group B (`ANTHROPIC_API_KEY` absent → designed 422) failures; byte-identical to base, not regressions; pass with keys set on the server. Architecture suite 129 passed (tier boundary moat HARD + executed). Pint `--dirty --test` clean.
- **Known-RED riding the release (CSJ explicit "ship & track"):**
`CassetteModelProvenanceTest:77` — 11 stranded `xai/grok-4-1-fast-reasoning` cassettes vs `grok-4.3` config. Pre-existing, not caused by this release, no runtime impact (LLM mocked in Pest). Fix (re-record via `eval:record --providers=xai` or delete the stale dir, confirm with CSJ before changing fixtures) tracked as a follow-up.

8. Deployment & rollback

- Production deploy per `CLAUDE.md` "Deploying to production": `git checkout main && git pull` → `./deploy/fynla-org/build.sh` → upload `public/build/` + changed PHP → SSH `php artisan migrate --force + cache:clear/config:clear/view:clear/route:clear + optimize` → smoke `https://fynla.org` → monitor `storage/logs/laravel.log` 10–15 min.
- Server env reminder: set `AI_AUDIT_HMAC_KEY` + `ANTHROPIC_API_KEY` so the Group A/B audit/provider tests are not the local-only failures above.
- **Rollback:** Fyn prompt — set `FYN_PROMPT_ARCH=legacy` (note the §3 caveat: legacy refuses the advice→capture write journey). Tiers/teaser — non-destructive backfill is reversible; capability behaviour is fully store-driven via the admin screen (no redeploy needed to adjust caps, prices or capability verbs).
- **Open follow-ups carried:** real tier prices + per-cohort conversion-tier decisions for grandfathered legacy paid subscribers (spec §22 A8/A9 — CSJ); csjones Revolut sandbox sync run; `CassetteModelProvenanceTest` fix; controller-side `income_allocations.source_id` ownership validation; legacy→SP2 frontend gating-layer rewrite; `KycGateChecker` delta doc-fix.

Deployed to production (`fynla.org`) on 2026-05-19. Companion to the user-facing `patch-notes-2026-05-19.md`. Internal refs: PR #337, #340; campaigns SP1 (#305–#324, #313), SP2 (#327–#336), SP3 (#332, #335).